BACKUP MANAGEMENT POLICY

POL-016 | Policy | Part of the Information Management Framework

Document ID: POL-016
Version: 1.0 — DRAFT
Classification: Internal Use
Owner: CIO
Co-Owner: Information Security
Effective Date: [DATE]
Review Date: [DATE + 1 Year]

CONFIDENTIAL — FOR INTERNAL USE ONLY

Document Control

Field	Detail
Document Title	Backup Management Policy
Document ID	POL-016
Version	1.0 — DRAFT
Parent Framework	IMF-001 — Information Management Framework
Related Documents	POL-002 (Data Retention), POL-003 (Data Integrity), POL-005 (System Classification), POL-006 (Computer System Validation), POL-007 (Change Management), POL-009 (PAM), POL-010 (IS Risk), POL-011 (Business Continuity), POL-012 (Incident Response), POL-014 (Audit Trail and Monitoring), SOP-016 (Backup and Restore Process), SOP-011 (BC/DR Process), SOP-006 (Validation Process), EXC-001 (Exception Management), RACI-001
Owner	CIO
Co-Owner	Information Security Manager
Approved By	[Approver Name and Title]
Effective Date	[DATE]
Next Review Date	[DATE + 1 Year]

Revision History

Version	Date	Author	Description
0.1	[DATE]	[Author]	Initial draft
1.0	[DATE]	[Author]	Issued for review

1. Purpose and Scope

This policy establishes the mandatory requirements for backup management at [Company Name] — covering the configuration, scheduling, encryption, monitoring, access control, retention, and restoration testing of all backup data. It closes the gap between the recovery time and recovery point objectives defined in POL-011 (Business Continuity Policy) and the operational controls that must exist to deliver them.

This policy applies to all [Company Name] systems that hold data with a retention obligation under POL-002, all GxP systems regardless of data volume, all SOX ITGC systems, and all Tier 1 and Tier 2 systems as defined in POL-005. Backup infrastructure itself — backup servers, backup software, cloud backup vaults, and tape management systems — is in scope as a Tier 1 asset irrespective of the tier of the systems it protects.

IMPORTANT: The RPO targets in POL-011 are only achievable if the backup programme actually delivers recoverable data to the required point. This policy is the control that makes those targets operational. Where backup capability cannot meet a system's RPO, that gap is an IS Risk (SOP-010) — it is not acceptable to set an RPO target and not have backup controls capable of meeting it.

2. Backup Schedule and Type Requirements

Backup schedules are mandatory minimums — system owners may implement more frequent backups where the RPO target or the volume of transactions warrants it. Reducing backup frequency below the mandatory minimum requires an EXC-001 exception.

System Tier	RPO Target (from POL-011)	Mandatory Backup Frequency	Backup Types Required	Offsite / Cross-Region
Tier 1	1 hour	Continuous replication or snapshot every 1 hour minimum. Full backup weekly.	Continuous replication (synchronous or near-synchronous) to DR site, OR hourly incremental snapshot with weekly full. Point-in-time recovery capability required: minimum 30-day retention of recovery points.	Mandatory. Backup or replica must be in a geographically separate region or data centre from the primary. Same-region copies do not meet this requirement.
GxP systems	Per tier assignment,	Same as tier requirements above,	Full backup minimum daily.	Mandatory. GxP data must not exist

System Tier	RPO Target (from POL-011)	Mandatory Backup Frequency	Backup Types Required	Offsite / Cross-Region
(any tier)	minimum 1 hour for Tier 1 GxP	with the additional requirement that the backup programme captures audit trail data on the same schedule as application data — audit trail data must not lag application data.	Incremental or continuous as required by RPO. Audit trail backups must be verified separately (see Section 5).	in a single geographic location.
Tier 2	4 hours	Minimum every 4 hours (or at each significant transaction boundary where practical). Full backup daily.	Daily full plus incremental at the RPO cadence, OR continuous replication where cost-justified.	Mandatory for systems holding personal data. Strongly recommended for all Tier 2 systems.
SOX ITGC systems	Per tier assignment	As per tier above. In addition: a point-in-time snapshot immediately before and immediately after any financial period close.	Financial period-close snapshots retained for 7 years minimum per POL-002, regardless of other backup retention settings.	Mandatory.
Tier 3	24 hours	Daily full backup.	Daily full.	Recommended. Mandatory where system holds personal data.
Tier 4	72 hours	Minimum weekly full backup.	Weekly full.	Not required unless system holds personal data.

3. Encryption Requirements

All backup data is subject to encryption requirements that are at least as stringent as those applied to the primary data. The classification of the data in the backup determines the encryption standard — the act of backing up data does not reduce its classification or its encryption obligation.

Requirement	Standard
Encryption in transit	All backup data transmitted over any network — including internal networks — must be encrypted using TLS 1.2 minimum. TLS 1.3 preferred. Unencrypted backup traffic over any network segment is

Requirement	Standard
	prohibited.
Encryption at rest	All backup storage — disk, tape, object storage, cloud vault — must use AES-256 encryption at rest. This applies to all system tiers. There is no tier below which encryption at rest is optional.
Key management	Backup encryption keys must be managed separately from the systems being backed up. A ransomware or cryptographic attack that compromises the primary system must not simultaneously compromise the backup encryption keys. Keys stored in a cloud HSM or on-premises HSM. Key access: CIO and Data Custodian (IT) only. Key rotation: annual minimum, or immediately on suspected compromise.
GxP backup encryption	GxP backup encryption configuration is a validated parameter — it is assessed during IQ/OQ (SOP-006) and any change to encryption configuration is a Normal Change (SOP-007) requiring Compliance / QA review and a validation impact assessment.
Tape backups	Where tape media is used: FIPS 140-2 Level 2 or higher hardware encryption. Tape media classified at the same level as the highest-classified data on the tape. Tape transport to offsite storage: sealed, tracked, and signed chain of custody.

4. Offsite and Cross-Region Requirements

The purpose of offsite backup is to ensure that a single physical event — fire, flood, power failure, or a targeted attack on the primary site — cannot simultaneously destroy both primary data and all backup copies. This requirement cannot be met by a backup that is in the same building, the same campus, or the same cloud availability zone as the primary system.

Requirement	Standard
Minimum geographic separation	Offsite backup must be in a location that cannot be affected by the same physical event as the primary site. For cloud deployments: separate cloud region (not a second availability zone in the same region). For on-premises deployments: separate building at minimum, separate city preferred.
3-2-1 rule	[Company Name] adopts the 3-2-1 backup rule as the mandatory minimum for all Tier 1 and GxP systems: 3 copies of the data (primary + 2 backups); on 2 different storage media or technologies; with 1 copy offsite or in a separate cloud region.
Air-gap or immutable offsite copy	For Tier 1 systems and GxP systems: at least one backup copy must be air-gapped or stored in immutable (WORM) cloud storage. This copy must not be accessible from the primary production environment — a ransomware infection in production must not be able to reach and encrypt this copy. Review cadence: Data Custodian (IT) confirms air-gap integrity quarterly.

Requirement	Standard
Offsite access controls	Access to offsite backup storage is restricted to Data Custodian (IT) and CIO. Vendor access to offsite storage (cloud backup providers) is governed by SOP-013. Vendor backup support access is JIT per SOP-009.

5. GxP-Specific Backup Requirements

GxP backup requirements are additive to the tier requirements above. They reflect the specific obligations under 21 CFR Part 11, EU Annex 11, and ALCOA+ to ensure the completeness, accuracy, and authenticity of GxP records — including in backup form.

GxP Requirement	Standard
Audit trail backup completeness	Audit trails must be backed up on the same schedule as application data. An application backup that does not include the corresponding audit trail records for the same time period is incomplete and cannot support ALCOA+ Completeness. Data Custodian (IT) confirms audit trail inclusion in each backup run as part of the backup monitoring process (Section 6).
Backup as part of the validated system	The backup process for a GxP system is part of the validated system. Backup configuration (schedule, scope, encryption, retention) is documented in the System Description (SOP-006 VMF Section 3) and validated during OQ. Any change to backup configuration for a GxP system is a Change under SOP-007, requires a Validation Impact Assessment, and is subject to Compliance / QA review.
Restoration testing for GxP systems	The quarterly backup restoration test (SOP-016 Section 6) for GxP systems is a validation activity. The test protocol and results are documented in the VMF. A restoration test that fails to produce complete and accurate GxP records — including audit trails — is a validation failure requiring a deviation under SOP-006 Section 6.3.
Long-term archive integrity	GxP records have retention periods that may extend 15–25+ years. Backup media and formats used for long-term GxP archive must be assessed for longevity — Data Custodian (IT) reviews archival media and format viability as part of the annual backup programme review. Migration to new media or format is a Change under SOP-007 with Compliance / QA oversight.
Metadata preservation	GxP record backups must preserve all metadata fields — including original creation timestamps, user attribution, and audit trail linkages — in their original form. Backup processes that strip or modify metadata produce records that cannot satisfy ALCOA+ Attributable and Contemporaneous requirements.

6. Backup Retention

Backup retention is distinct from data retention. Data retention (POL-002) is the period for which data must remain accessible for business or regulatory use. Backup retention is the period for which backup copies are maintained. These interact but are not the same: the backup retention period must be long enough to support the data retention period, but backup copies are not a substitute for accessible primary storage for data that is still within its retention period.

Backup Category	Minimum Retention	Basis
Daily and incremental backups — general	30 days	Operational recovery window. Covers the typical discovery-to-detection delay for data corruption, accidental deletion, and early-stage ransomware infections.
Weekly full backups — general	90 days	Extended operational recovery window. Supports investigation of incidents that may not be detected within 30 days.
Monthly full backups — general	12 months	Annual recovery capability. Supports year-end forensic requirements.
Annual archive backup — Tier 1 and GxP	Per POL-002 retention schedule for the data category. GxP: minimum life of system plus applicable regulatory retention. SOX ITGC: 7 years.	Regulatory retention obligation. The annual archive backup is the long-term retention vehicle for data categories where POL-002 specifies retention beyond 12 months.
SOX period-close snapshots	7 years minimum	SOX Section 302/404 evidence. External auditor access may be required up to 7 years post-period.
Pre-change backups (SOP-007)	90 days or until the change is confirmed stable in production — whichever is longer	Change management rollback capability. The pre-change backup is the rollback vehicle if a change produces an undetected defect discovered weeks after implementation.
Incident preservation backups (SOP-012)	7 years or until legal proceedings are concluded — whichever is longer	Forensic and legal hold. Incident preservation backups must be placed under legal hold immediately on CISO instruction. They must not be subject to routine backup rotation or deletion policies while the hold is in force.

NOTE: Backup deletion is not exempt from data governance. When a backup is deleted at the end of its retention period, any personal data in that backup is deleted — which counts as a deletion event under GDPR. Automated backup expiry processes must be configured to respect any active legal

holds, DPO-imposed retention extensions, or GxP regulatory holds. Data Custodian (IT) confirms no active holds exist before approving automated deletion runs.

7. Access Controls for Backup Infrastructure

Backup infrastructure — backup servers, backup management consoles, cloud backup vaults, tape management systems, and backup encryption key stores — is classified Tier 1 regardless of the tier of the systems it serves. Access is governed by SOP-008 and SOP-009.

Access Type	Permitted Roles	Controls
Backup configuration (schedule, scope, retention, encryption settings)	Data Custodian (IT) only. Changes to GxP backup configuration require Compliance / QA co-approval.	Changes via SOP-007 Normal Change minimum. Backup configuration changes are logged and reviewed as part of the audit trail programme (SOP-014). GxP: Validation Impact Assessment required.
Backup execution (initiating manual backup runs)	Data Custodian (IT).	All manual backup initiations logged. Out-of-schedule manual backups require a documented reason. For GxP systems: Compliance / QA notified of any manual backup run outside the scheduled programme.
Restore operations	Data Custodian (IT) for technical execution. Restore authorisation: System Owner for the system being restored plus CIO for Tier 1 / GxP systems.	All restore operations logged: who requested, who authorised, who executed, what was restored, to where, at what recovery point. GxP restores require Compliance / QA notification before execution — validated state assessment per SOP-011 / SOP-016.
Backup deletion (manual deletion before retention expiry)	CIO only. Routine expiry handled by automated policy — manual deletion requires CIO approval.	Every manual deletion logged with approval reference. DPO notified if personal data affected. Legal confirmation that no hold is active.
Access to backup encryption keys	CIO and Data Custodian (IT).	Key access events logged. CISO notified of any key access outside a scheduled rotation or documented restore event.
Vendor / third-party access to backup infrastructure	JIT access per SOP-009. Tier A vendor with executed DPA per SOP-013.	PAM session recording mandatory for all vendor access to backup infrastructure.

8. Monitoring and Alerting

A backup that is not monitored is a backup that has failed without anyone knowing. The following monitoring requirements are mandatory — they are not optional enhancements.

Monitoring Requirement	Standard
Backup job completion monitoring	Every scheduled backup job must generate a completion event — success or failure — that is captured in the backup management system. Failed backup jobs generate an alert within 15 minutes of the failure being detected. Data Custodian (IT) receives all backup failure alerts. CIO receives alerts for Tier 1 and GxP system backup failures. Unacknowledged backup failure alerts escalate to CIO after 1 hour.
Missed backup detection	Where a backup job simply does not run (e.g., backup agent failure, system shutdown during backup window), the absence of a completion event must itself generate an alert. Monitoring must not only detect failed jobs — it must detect missing jobs. Absence of a backup run for a Tier 1 or GxP system is treated as a backup failure.
Backup storage capacity	Backup storage utilisation is monitored continuously. Alerts at 80% capacity (warning) and 90% capacity (critical). A backup storage capacity failure that causes backup jobs to fail is a Tier 1 operational incident per SOP-015.
Offsite replication lag	For systems using continuous or near-continuous replication, replication lag is monitored in real time. Alert if lag exceeds 50% of the RPO target — i.e., for a 1-hour RPO system, alert if replication lag exceeds 30 minutes. Replication lag that approaches or exceeds the RPO target is a potential RPO breach and is escalated to CIO.
Backup integrity (hash verification)	Where the backup platform supports it: backup integrity hash verification is enabled on all Tier 1 and GxP backup jobs. A hash verification failure generates an immediate alert to Data Custodian (IT) and CIO. A backup set with a failed integrity check must not be used as a restore source until the failure is investigated and resolved.
SIEM integration	Backup management system logs are forwarded to the SIEM per POL-014. Backup access events, deletion events, configuration changes, and encryption key access events are monitored under the SOP-014 monitoring programme.

9. Restoration Testing

Backup restoration testing confirms that backups are actually recoverable — not just that the backup job completed successfully. Completion of a backup job is evidence that data was

written to a backup medium. Restoration testing is evidence that the data can be read back and is complete, accurate, and usable.

Test Type	Scope	Frequency	Pass Criteria	GxP Requirement
Full restoration test	Complete restore of Tier 1 system to an isolated environment. All data and configuration restored from backup.	Annual. Coordinated with SOP-011 DR full failover test where possible — the DR test may serve as the annual full restoration test if it uses backup as the restore source.	System restores successfully to the target recovery point. All data confirmed complete and accurate. Application functions correctly in the restored environment. Restore time within RTO target.	Audit trail data confirmed complete and intact in the restored environment. Metadata preserved. Compliance / QA confirms restored GxP records satisfy ALCOA+ requirements. Test result documented in VMF as a validation activity.
Partial / file-level restoration test	Restore of a representative sample of files or records from Tier 2 and Tier 3 systems. Minimum 5% of records or 100 records (whichever is smaller) from a randomly selected backup set.	Quarterly for Tier 1 and GxP. Biannual for Tier 2. Annual for Tier 3.	Selected records restore successfully. Data is complete and matches the expected content for the recovery point. Restore time within expectations.	For GxP: randomly sampled records include audit trail records. Metadata confirmed preserved.
Backup integrity verification	Hash or checksum verification of the backup set without a full restore.	Monthly for Tier 1 and GxP. Quarterly for Tier 2.	All hashes verified successfully. No corrupted or unreadable segments in the backup set.	Data Custodian (IT) confirms. DIO reviews results for GxP systems.

Restoration test results are documented and retained. Test failures are findings — they are not suppressed or informally resolved. A failed restoration test generates an IS Risk Register entry (SOP-010), a problem record in SOP-015, and a remediation plan. For GxP systems: a failed restoration test is a deviation under SOP-006. The subsequent successful test is the evidence of effective remediation.

10. Exceptions

Exceptions to requirements in this policy are governed by EXC-001. The following exception constraints apply specifically to backup management:

Exception Type	Approval Level	Maximum Duration	Non-Approvable
Backup frequency below mandatory minimum for Tier 2 or below	Information Security Manager + CIO	3 months with compensating controls (e.g., more frequent manual snapshots)	No
Backup frequency below mandatory minimum for Tier 1	CISO + CIO + Board notification	1 month maximum. IS Risk Register entry mandatory.	No — but Board notification required
Absence of offsite backup for Tier 2 or below	Information Security Manager	3 months with documented remediation plan	No
Absence of offsite backup for Tier 1 or GxP	CISO + CIO	Cannot be approved — offsite is mandatory for Tier 1 and GxP. Architecture must be remediated. IS Risk Register entry and Board notification while gap exists.	Yes — cannot be waived
Backup encryption below AES-256 for any tier	CISO + CIO	Cannot be approved — AES-256 is the mandatory minimum for all tiers.	Yes — cannot be waived
GxP backup configuration change without Validation Impact Assessment	Non-approvable	—	Yes — this is a data integrity requirement. Any unapproved backup configuration change on a GxP system is a deviation per SOP-006.

11. Related Documents

Document ID	Title	Relationship
SOP-016	Backup and Restore Process	Operationalises this policy — defines the step-by-step procedures for backup configuration, monitoring, restoration testing, and restore execution

Document ID	Title	Relationship
POL-011	Business Continuity Policy	RPO targets that this policy's backup programme must deliver. Backup failure to meet RPO is a BC risk.
SOP-011	BC/DR Process	Restore from backup is the primary recovery mechanism in BC/DR events. SOP-011 references SOP-016 for backup availability and restoration procedures.
POL-002	Data Retention and Disposal Policy	Data retention periods define the minimum lifetime of annual archive backups. Backup deletion must respect active retention holds.
POL-003	Data Integrity Policy	GxP backup completeness and metadata preservation are ALCOA+ requirements derived from POL-003.
POL-005	System Classification Policy	System tier determines backup schedule, RPO target, offsite requirements, and restoration test cadence.
POL-006	Computer System Validation Policy	GxP backup configuration is a validated parameter. Backup restoration test for GxP systems is a validation activity documented in the VMF.
POL-007	Change Management Policy	Changes to backup configuration for any system are Changes under POL-007. GxP backup configuration changes require VIA.
POL-009	PAM Policy	Privileged access to backup infrastructure governed by SOP-009. All vendor backup support access is JIT with session recording.
POL-010	IS Risk Policy	Backup programme gaps (failed restoration tests, RPO mismatches, absent offsite copies) are IS risks entered in the IS Risk Register via SOP-010.
POL-012	Incident Response Policy	Incident preservation backups placed under legal hold per CISO instruction. Restoration from backup during security incident recovery per SOP-012 Section 5 Step 6.
POL-014	Audit Trail and Monitoring Policy	Backup management system logs forwarded to SIEM. Backup events monitored per SOP-014 monitoring programme.
EXC-001	Exception Management Policy and Register	Exceptions to backup requirements governed by EXC-001 subject to constraints in Section 10 of this policy.
RACI-001	Roles, Responsibilities and Authorities	Accountability for backup management governance.

— End of Document —

POL-016 v1.0 DRAFT | [Company Name] | INTERNAL USE